Examen: **n°435061 "*QCM Cybersécurité SLAM1 2ème semestre*"**
Copie n°**11213766** / **SIO1 - SLAM**
Reference de l'examen: 250327-13757-186835-435061

Exam effectué depuis l'adresse IP 83.159.14.169 en utilisant le login OTP sabetha72 / 2951
Commencé le 2025-03-27 13:36:50 et terminé le 2025-03-27 13:53:03

Note : 18/20 (46 points / 52) - 46 questions
Barème: (Barème 1) Demi-point attribué si au moins la moitié des bonnes réponses sont cochées

(Examen ouvert le 2025-03-27 13:20:00)

Légende
✅ Correct
⚠ Devait être coché
❌ Faux

1 **(1 point)** - Pourquoi le ***chiffrement*** des ***cookies de session*** est-il recommandé ?
A ○ Parce que cela permet aux navigateurs de stocker plus de cookies
B ○ Pour empêcher l'utilisateur de voir ses propres cookies
C ○ Pour accélérer les requêtes HTTP entre le client et le serveur
D ✅ Pour éviter que des cookies interceptés puissent être exploités par un attaquant
(1 point / 1) Question à choix multiple

2 **(1 point)** - Une ***Routed SQL Injection*** consiste à : :
A ○ d'attaquer le routeur du serveur
B ○ passer en root sur MySQL
C ○ reseter la Bdd
D ✅ injecter une injection à destination de la requête suivante
(1 point / 1) Question à choix multiple

3 **(1 point)** - Quelle est une bonne pratique pour éviter les attaques ***Path Traversal*** ?
A ❌ Mettre un mot de passe sur chaque fichier système sensible
B ○ Utiliser uniquement des chemins d'accès absolus dans le code
C ○ Stocker les fichiers sensibles dans le répertoire /public pour qu'ils ne soient pas cachés
D ✅ Restreindre l'accès aux fichiers avec des règles spécifiques et vérifier les entrées utilisateur
(0 point / 1) Question à choix multiple

4 **(1 point)** - Pourquoi l'obfuscation du code source n'est-elle pas une mesure de ***sécurité*** suffisante ?
A ○ Parce qu'elle empêche les utilisateurs de modifier le code
B ○ Parce qu'elle augmente la performance du site
C ○ Parce qu'elle est automatiquement activée sur tous les navigateurs modernes
D ✅ Parce qu'elle ne bloque pas l'analyse du code et peut être contournée
(1 point / 1) Question à choix multiple

5 **(1 point)** - Quelle technique peut être utilisée pour contrer une attaque par ***force brute*** sur un mot de passe ?
A ○ Remplacer les mots de passe par des questions secrètes
B ✅ Limiter le nombre de tentatives de connexion avec un délai progressif
C ❌ Interdire l'accès au serveur après 3 échecs de connexion
D ○ Changer automatiquement tous les mots de passe toutes les 24 heures
(0 point / 1) Question à choix multiple

6 **(1 point)** - Quel opérateur SQL permet de "concaténer" ***verticalement*** une nouvelle requête à la requête d'origine ? :
A ○ JOIN
B ○ SELECT+
C ○ CONCAT
D ✅ UNION
E ○ GROUP BY
(1 point / 1) Question à choix multiple

7 **(2 points)** : Si une application est sensible à l'***injection SQL***, qu'est ce qui est vrai concernant la méthode d'attaque complémentaire utilisant l'instruction UNION ALL ?
A ✅ elle permet d'afficher le contenu d'autres tables dans la même base de données
B ✅ elle permet d'afficher le contenu d'autres tables dans d'autres bases de données (si le compte utilisateur de

la connexion a les droits de lecture)
C on a généralement besoin de compléter avec des NULL pour "matcher" le nombre de colonnes de la table principale
D on a généralement besoin d'avoir des informations sur les noms de tables puis de colonnes à partir de métadonnées connues (par exemple information_schema.columns)
E on complète toujours avec 3 NULL, le 1er pour le id, le 2ème pour le login et le 3ème pour le mot de passe
F on fait un UNION SELECT * FROM Table sur la table qu'on veut lire
(1 point / 2) Question à choix multiple

---

8 **(1 point)** - Quel est l'impact d'une ***attaque MITM*** sur une connexion non sécurisée ?
A Permet à l'attaquant de modifier ou d'intercepter les données échangées
B Ne fonctionne pas si le site cible utilise un mot de passe long
C Nécessite l'accès physique au serveur ciblé
D Peut uniquement être menée sur des réseaux Wi-Fi publics
(1 point / 1) Question à choix multiple

---

9 **(1 point)** - Pourquoi une ***URL*** contenant un identifiant utilisateur est-elle risquée ?
A Car elle force l'utilisation du protocole HTTPS
B Car elle empêche l'accès aux pages sans connexion
C Car elle permet d'exécuter du code SQL sur le serveur
D Car un attaquant peut modifier l'ID et accéder aux données d'un autre utilisateur
(1 point / 1) Question à choix multiple

---

10 **(1 point)** - Pourquoi l'authentification à deux facteurs (2FA) peut-elle être ***inefficace*** ?
A Si le site web ne propose pas d'authentification biométrique
B Si elle est mal implémentée et que l'attaquant peut contourner la vérification
C Si l'utilisateur utilise un mot de passe fort
D Si elle est utilisée avec un mot de passe long
(1 point / 1) Question à choix multiple

---

11 **(1 point)** - Quel type de données est le plus exposé aux ***attaques*** **XSS** ?
A Les fichiers logs des serveurs
B Les fichiers PDF téléchargés sur un site Web
C Les données saisies par les utilisateurs et renvoyées sans validation dans une page Web
D Les styles CSS d'un site
(1 point / 1) Question à choix multiple

---

12 **(1 point)** - Quel fichier système peut être une ***cible*** d'attaque ***Path Traversal*** sous Windows ?
A C:UsersPublicDocumentsconfig.txt
B C:WindowsSystem32cmd.exe
C C:WindowsTemplogs.txt
D C:WindowsSystem32driversetchosts
(1 point / 1) Question à choix multiple

---

13 **(1 point)** - Pourquoi est-il dangereux de laisser une page ***phpinfo()*** accessible en production ?
A Parce qu'elle donne accès aux logs des utilisateurs
B Parce qu'elle affiche des informations sensibles sur la configuration du serveur
C Parce qu'elle permet d'exécuter directement du code PHP
D Parce qu'elle permet de modifier des fichiers système
(1 point / 1) Question à choix multiple

---

14 **(1 point)** - Quel est le principal objectif d'une attaque ***Path Traversal*** ?
A Injecter du code JavaScript dans une page web
B Réinitialiser les mots de passe des administrateurs
C Lancer un déni de service (DDoS) contre le serveur
D Accéder à des fichiers sensibles du serveur en manipulant les chemins d'accès
(1 point / 1) Question à choix multiple

---

15 **(1 point)** - En cas d'***injection SQL*** quel est le périmètre remis en question ? :
A uniquement la table visée
B uniquement l'enregistrement visé
C tout le serveur
D uniquement la base de données visée
(1 point / 1) Question à choix multiple

©Evalbox

16 **(1 point)** - Quelle est une bonne pratique pour sécuriser les ***connexions HTTPS*** ?
A ❌ Mettre un CAPTCHA sur toutes les pages de connexion
B ◯ Désactiver le chiffrement des connexions pour éviter les attaques MITM
C ✅ Forcer l'utilisation de HTTPS avec HSTS (HTTP Strict Transport Security)
D ◯ Faire confiance à tous les certificats SSL auto-signés
(0 point / 1) Question à choix multiple

17 **(2 points)** - Quels sont les principaux ***risques*** associés aux **injections SQL**? :
A ◯ phishing par SMS/email
B ✅ perte de données
C ◯ suppression du Firewall
D ✅ exposition d'informations sensibles
E ✅ ralentissement des performances de la base de données
(2 points / 2) Question à choix multiple

18 **(1 point)** - Comment éviter les attaques XSS ***DOM-Based*** ?
A ◯ En mettant tous les scripts JavaScript dans un fichier séparé
B ◯ En interdisant les requêtes AJAX sur le site
C ◯ En activant JavaScript uniquement pour les administrateurs
D ✅ En contrôlant les entrées utilisateur avant de les insérer dans le DOM
(1 point / 1) Question à choix multiple

19 **(1 point)** - La ***Time-Based Blind*** SQL Injection :
A ◯ reset l'horloge interne du serveur
B ◯ ne se fait qu'à une certaine heure UTC
C ◯ permet de ralentir la vitesse de traitement du serveur
D ✅ exploite le temps de réponse du serveur
(1 point / 1) Question à choix multiple

20 **(2 points)** - Quels sont les entrées susceptibles d'être attaquées par ***injection SQL*** ? :
A ◯ Les liens hypertextes statiques
B ✅ L'URL (via les paramètres GET)
C ◯ Les fichiers CSS d'un site web
D ✅ Tous les champs d'un formulaire
E ◯ Uniquement les champs de type 'text'
F ◯ Les images uploadées sur le serveur
(2 points / 2) Question à choix multiple

21 **(1 point)** - La requête suivante
"SELECT * FROM users WHERE codeacces=$code AND (pass='$passwd')"
peut se faire attaquer
A ✅ $code = 1234 et $passwd = " a') OR '1'='1' -- "
B ◯ $code = 1234 et $passwd = " a OR 1=1') -- "
C ◯ $code = 1234 et $passwd = " a' OR 'a'='b' -- "
D ◯ $code = 1234 et $passwd = " a' OR '1'='1') -- "
(1 point / 1) Question à choix multiple

22 **(1 point)** - Quelle protection empêche les scripts XSS de s'exécuter sur une page web ?
A ◯ Le stockage des scripts JavaScript en base de données
B ◯ L'ajout d'un mot de passe sur chaque page sensible
C ◯ L'utilisation de fichiers .htaccess
D ✅ L'activation de Content Security Policy (CSP)
(1 point / 1) Question à choix multiple

23 **(1 point)** - Quelle est une bonne pratique pour ***protéger les données sensibles*** stockées en base de données ?
A ⚠ Les chiffrer avec des algorithmes forts et ne jamais stocker de mots de passe en clair
B ◯ Stocker les mots de passe dans un fichier texte avec un accès restreint
C ◯ Conserver toutes les données sans chiffrement mais les renommer pour les masquer
D ◯ Activer uniquement les logs SQL pour détecter les accès malveillants
(0 point / 1) Question à choix multiple

24 **(1 point)** - Quelle est la principale différence entre une attaque **XSS *réfléchie*** et une attaque **XSS**

persistante ?

A ✅ L'attaque XSS réfléchie cible une seule victime à la fois, tandis que l'attaque XSS persistante affecte tous les visiteurs d'une page infectée
B ◯ L'attaque XSS réfléchie est plus dangereuse que l'attaque XSS persistante
C ◯ L'attaque XSS réfléchie ne permet jamais de voler des sessions
D ◯ L'attaque XSS persistante ne fonctionne que sur les sites e-commerce

(1 point / 1) Question à choix multiple

---

25 (1 point) - Quelles contre-mesures permettent de limiter les attaques par ***force brute*** ?

A ◯ Forcer un changement de mot de passe après chaque connexion
B ◯ Permettre uniquement des mots de passe de 20 caractères minimum
C ✅ Utiliser des captchas après un certain nombre de tentatives
D ✅ Limiter le nombre de tentatives et imposer un délai après plusieurs échecs

(1 point / 1) Question à choix multiple

---

26 (1 point) - Le moyen de se protéger des ***injections*** SQL est:

A ◯ d'utiliser un firewall
B ◯ d'utiliser Linux
C ◯ de mettre un anti-virus récent et maintenu à jour
D ✅ d'utiliser les requêtes préparées paramétrées

(1 point / 1) Question à choix multiple

---

27 (1 point) - Quelles sont les conséquences possibles d'une ***attaque XSS*** ?

A ✅ Usurpation d'identité sur un site Web
B ◯ Ne peut causer aucun dommage réel si le site ne contient pas de base de données
C ✅ Vol des cookies d'authentification
D ◯ Déclenchement automatique d'un ransomware

(1 point / 1) Question à choix multiple

---

28 (1 point) - Pour découvrir quel type de ***base de données*** est utilisé pour un site web, on peut :

A ✅ tenter de provoquer des erreurs
B ◯ analyser les résultats affichés
C ◯ forcer l'affichage d'une page 404 verbeuse

(1 point / 1) Question à choix multiple

---

29 (1 point) - Quelle contre-mesure est recommandée pour empêcher une ***attaque XSS*** ?

A ◯ Mettre un pare-feu pour bloquer le JavaScript
B ✅ Échapper les caractères spéciaux et valider les entrées utilisateur
C ◯ Stocker les entrées utilisateur directement dans la base de données sans filtrage
D ◯ Désactiver complètement JavaScript sur les navigateurs des utilisateurs

(1 point / 1) Question à choix multiple

---

30 (1 point) - Il est impossible de faire une injection SQL sur:

A ◯ SQLite
B ◯ SQL server
C ◯ MariadB
D ✅ un fichier texte
E ◯ PostgreSQL
F ◯ Mysql

(1 point / 1) Question à choix multiple

---

31 (1 point) - Quelles sont les conséquences possibles d'une fuite d'***informations confidentielles*** ?

A ◯ Blocage automatique du site par tous les navigateurs
B ✅ Perte de confiance des clients
C ✅ Espionnage industriel
D ✅ Usurpation d'identité

(1 point / 1) Question à choix multiple

---

32 (1 point) - Pourquoi un ***panneau d'administration*** mal sécurisé est-il une cible privilégiée ?

A ◯ Il désactive automatiquement les pare-feu et antivirus
B ✅ Il peut permettre un accès complet au système ou à la base de données
C ◯ Il contient toujours une liste des utilisateurs et mots de passe en clair
D ◯ Il permet d'intercepter toutes les communications réseau

(1 point / 1) Question à choix multiple

©Evalbox

33 **(1 point)** - Quel est un exemple de mauvaise pratique en matière de ***gestion des sessions*** ?
A ✓ Stocker l'ID de session directement dans l'URL
B Demander aux utilisateurs de changer de mot de passe tous les 30 jours
C Forcer une reconnexion après 10 minutes d'inactivité
D Utiliser une base de données pour stocker les sessions
(1 point / 1) Question à choix multiple

34 **(1 point)** - Qu'est-ce qu'une ***injection SQL*** ? :
A L'ajout d'un programme SQL dans le système linux afin de bloquer toute connexion
B ✓ La modification (non prévue) d'une chaine de caractère dans une requête afin de détourner son objectif
C Un terme geek équivalent à dumper la database
(1 point / 1) Question à choix multiple

35 **(1 point)** - La ***Blind SQL*** Injection :
A rend aveugle les autres utilisateurs
B ✓ analyse les réponses du serveur pour déterminer si une condition est vraie ou fausse
C n'existe pas
D récupère tous les caractères même ceux invisibles
(1 point / 1) Question à choix multiple

36 **(1 point)** - L'attaque par ***SQL Truncation*** consiste à : :
A sélectionner toutes les tables en une seule requête
B afficher le mot de passe admin
C vider la table (Truncate)
D ✓ utiliser une donnée trop longue afin de tenter d' insérer un doublon
(1 point / 1) Question à choix multiple

37 **(1 point)** - Quelles techniques peuvent être utilisées pour protéger les utilisateurs contre le ***vol de sessions*** ?
A Stockage des sessions côté client pour plus de sécurité
B ✓ Rotation des identifiants de session après authentification
C ✓ Utilisation de cookies sécurisés avec l'attribut HttpOnly
D Remplacement des cookies de session par des questions secrètes
(1 point / 1) Question à choix multiple

38 **(1 point)** - L'attaque dite ***Error-Based*** SQL Injection : :
A ne fonctionne jamais
B ✓ permet d'obtenir des informations sur la BDD
C liste toutes les erreurs de configuration de la BDD
(1 point / 1) Question à choix multiple

39 **(1 point)** - Quel est le principal danger d'un ***vol de session*** ?
A Peut être bloqué uniquement en changeant régulièrement les mots de passe
B Nécessite toujours un accès physique au serveur pour fonctionner
C Ne fonctionne pas si l'attaquant ne connaît pas le login exact de la victime
D ✓ Permet à un attaquant d'usurper l'identité d'un utilisateur légitime
(1 point / 1) Question à choix multiple

40 **(1 point)** - Quel est le principal risque d'un ***cookie de session*** mal protégé ?
A Les cookies expirent plus vite et obligent à se reconnecter souvent
B Un attaquant peut forcer un utilisateur à se déconnecter
C Un cookie mal protégé permet d'exécuter du code directement sur le serveur
D ✓ Un attaquant peut voler la session et usurper l'identité d'un utilisateur
(1 point / 1) Question à choix multiple

41 **(2 points):** Dans une application PHP nommée Mutilidae, les requêtes SQL ne sont pas protégées et on trouve le code suivant:

```
$lQueryString =
    "SELECT * FROM accounts
    WHERE username='".$pUsername.
    "' AND password='".$pPassword."'";
```

Quel type de saisie (et donc d'injection), dans le champ Utilisateur (Name) récupéré dans la variable

$pUserName permet de bypasser l'authentification ?
A ' AND 1=1 --
B ✅ ' OR 1=1 --
C " AND 1=1 --
D " OR 1=1 --
(2 points / 2) Question à choix multiple

---

42 **(1 point)** - Quelle faille permet à un attaquant de manipuler des ***requêtes API*** mal sécurisées ?
A ✅ L'absence de contrôle d'accès et de validation des paramètres envoyés
B L'utilisation de requêtes AJAX dans le frontend
C Le stockage des sessions dans une base de données
D Le chiffrement des données avant l'envoi au serveur
(1 point / 1) Question à choix multiple

---

43 **(2 points)** - Pour MySQL, quels sont les moyens en commun de ***commenter*** une opérande : :
A / commentaire
B ✅ #commentaire
C <!-
D ✅ -- commentaire
E ✅ /*commentaire*/
(2 points / 2) Question à choix multiple

---

44 **(1 point)** - Quelle est la conséquence principale d'une **attaque** par *énumération* des logins ?
A Peut être évitée en activant simplement un antivirus sur le serveur
B Déclenche immédiatement une alerte de sécurité et bloque l'IP de l'attaquant
C ❌ Permet d'obtenir directement le mot de passe d'un utilisateur
D ⚠ Permet de tester une liste de logins pour identifier ceux qui existent
(0 point / 1) Question à choix multiple

45
(2 points): Injection PHP - Analyse de code

Dans une application PHP quelconque, on trouve le code suivant pour la validation d'un utilisateur:

```
$lQueryString =
    "SELECT * FROM accounts
    WHERE username='".$pUsername.
    "' AND password='".$pPassword."'";
```

Qu'est ce qui est vrai ?
A L'application est protégée contre les injections
B ✅ On ne peut pas dire avec cet extrait si l'application est sensible ou pas aux injections
C ✅ *Si l'application est sensible aux injections*, on l'attaquera dans le champ correspondant à pUsername, un commentaire en fin de saisie permettra d'ignorer le password
D L'application n'est pas protégée contre les injections
(2 points / 2) Question à choix multiple

---

46 **(1 point)** - Comment peut-on protéger un *cookie de session* contre le vol ?
A En stockant les sessions dans une base de données locale
B En chiffrant les cookies avec une clé privée sur le client
C En forçant une reconnexion toutes les 10 minutes
D ✅ En utilisant les attributs HttpOnly et Secure
(1 point / 1) Question à choix multiple

©Evalbox